



HIDDENLAYER

PROTECT YOUR ADVANTAGE

March 11, 2025

**To: National Science Foundation: Office of Science and Technology
Policy (OSTP)**

Attn: ostp-ai-rfi@nitrd.gov

HiddenLayer comments on

Office of Science and Technology (OSTP): Request for Information on the Development of an
Artificial Intelligence (AI) Action Plan

OVERVIEW

HiddenLayer appreciates the opportunity to provide feedback to the OTSP as it works to define the priority policy actions needed to sustain and enhance America's AI dominance, and to ensure that unnecessarily burdensome requirements do not hamper private sector AI innovation.

Artificial intelligence is no longer an emerging force – it is an embedded reality shaping economies, industries, and societies at an unparalleled scale. Every mission, organization, and individual has felt its impact, with AI driving efficiency, automation, and problem-solving breakthroughs. Yet, as its influence expands, so too do the risks.

The AI landscape is evolving rapidly, with open-source models and smaller, more accessible architectures accelerating innovation and risk. These advancements lower the barrier to entry, allowing more organizations to leverage AI but they also widen the attack surface, making AI systems more susceptible to manipulation, data poisoning, and adversarial exploitation. Meanwhile, hyped new model trends like DeepSeek are introducing unprecedented risks and impacting geopolitical power dynamics.

HiddenLayer at the core is about innovation. Innovation in AI and innovation in security for AI. We believe both are required to ensure our countries long term economic competitive advantage and to ensure our national security.

The HiddenLayer team was born out of a real-world adversarial machine learning attack in 2019 when Chris Sestito, Jim Ballard, and Tanner Burns (the HiddenLayer founders) were responsible for responding to a serious, real-world adversarial machine learning attack. At the time, Chris Sestito (HiddenLayer CEO) led Threat Research at Cylance, an AI company that revolutionized the anti-virus industry by leveraging deep learning to prevent malware attacks. In 2019, the Windows

executable ML model was exploited via what is now known as an inference attack, exposing its weaknesses and allowing the attackers to successfully evade detection anywhere Cylance was running. During the response effort, the future HiddenLayer founders saw it as a precursor of attacks to come made possible by the inherent weaknesses in AI/ML, more open source attack tools, and increasing knowledge of and usage of the fastest growing, most important technology the world has ever seen. Determined to prove that these attacks were preventable, the team developed a unique, patent-pending, productized security for AI solution to help all organizations mitigate security risks inherent within AI based solutions.

Despite the rapid growth of AI across every industry, many organizations unknowingly expose themselves to vulnerabilities, malware, and adversarial attacks due to insufficient investment in and education about current AI threats.

Our recently released AI threat report identified the following:

- 89% of organizations have AI models in production use that are business critical
- 74% of organizations have experienced an AI breach
- 45% of AI breaches were from malware already embedded in models
- 33% experienced an attack on an internal or external chatbot
- Only 32% of organizations have deployed technology to secure AI
- Only 16% of organizations are utilizing red teaming AI to enhance their security posture

HiddenLayer is addressing a critical gap to secure and accelerate the use of Artificial Intelligence (AI), one of the world's most valuable technologies. We believe policy actions that encourage innovations without unnecessary burdens in AI and Security for AI will create long term durable economic, national security, and societal benefits for our country.

HiddenLayer's Model Scanner ensures models are free from adversarial code before entering corporate environments. Scan models securely from public repositories before deploying on-premise or as a service with no disruption. Backed by industry recognition, including the RSA Sandbox Award, the Model Scanner integrates seamlessly with modern ML development lifecycles and SecOps workflows. In this era of AI/ML innovation, the Model Scanner is a critical component for rapid collaboration and innovation. Trust, flexibility, and comprehensiveness are non-negotiable when it comes to ensuring your business stays ahead in innovation.

HiddenLayer's Automated Red Teaming capability for AI enables security teams with one-click vulnerability testing for AI solutions. Leveraging our industry leading AI research and professional red teaming services, this tool simulates expert attacks with zero lead time, providing detailed reports to identify, remediate, and document security risks — improving the velocity of AI projects ensuring they remain on track.

Our AI Security (AISec) Platform, provides comprehensive security that collectively protects AI models against adversarial attacks, vulnerabilities, and malicious code injections. Each product within AISec Platform is designed with unique strengths and capabilities for detecting and responding to attacks, creating a well-rounded defensive strategy against threats. HiddenLayer's flagship AI Detection and Response (AIDR) product provides a noninvasive, software-based approach to monitoring the inputs and outputs of AI algorithms. AIDR offers real-time defense to

an otherwise unprotected asset and flexible response options, including alerting, isolation, profiling, and misleading.

With the AI market projected to reach \$16 trillion by 2030, our mission is to empower governments, academic institutions, and corporations to embrace AI responsibly, ensuring the secure and accelerated adoption of this invaluable technology.

In September of 2023 HiddenLayer raised \$50M in Series A funding to expand its talent base, increase go-to-market efforts, and further invest in our Artificial Intelligence Security (AISec) Platform. The investment marks the largest Series A funding raised by a cybersecurity company focused on protecting AI. The funding was led by [M12, Microsoft's Venture Fund](#), and Moore Strategic Ventures, with participation from [Booz Allen Ventures](#), [IBM Ventures](#), [Capital One Ventures](#), and [Ten Eleven Ventures](#). [Press Release](#).

We have seen strong demand for our AISec Platform across a wide range of organizations since the company launched in July of 2022. We are working closely with many of the largest financial, healthcare, and retail organizations, universities, and the US government. We were proud to publicly announce our recent partnership with the Department [of the Air Force \(DAF\)](#) in October of 2023 and the [phase 2](#) contract in April 2024. We are also excited to have recently announced a [collaboration](#) with Microsoft Azure AI to enhance [model security](#).

Priority Policy Recommendations

As the global leader in artificial intelligence (AI), the United States must ensure that its AI policies promote innovation while safeguarding national security, data privacy, and the integrity of AI systems. To maintain a durable economic advantage, AI policies should optimize security with flexibility, allowing private sector innovation to flourish unimpeded by unnecessary regulatory burdens. This document outlines HiddenLayer's key policy recommendations aimed at reinforcing America's position as an AI powerhouse.

1. Ensuring Explainability and Assurance of AI Model Outputs

- Promote the development of industry-led standards for AI explainability that align with international best practices, ensuring that AI decision-making remains transparent without imposing rigid, one-size-fits-all requirements.
- Encourage the adoption of assurance mechanisms, such as model validation and testing frameworks, to improve trustworthiness and reliability in AI outputs.
- Invest in research and development for interpretability tools that enhance AI explainability without compromising model performance.
- Support initiatives that provide guidance on secure AI deployment, ensuring that businesses can adopt AI without undue liability risks.

2. Strengthening Cybersecurity Measures for AI Systems

- Establish voluntary cybersecurity best practices for AI developers to integrate security-by-design principles, thereby mitigating risks of adversarial attacks and data poisoning.

- Incentivize private-sector investment in robust cybersecurity frameworks through tax credits and public-private partnerships that enhance AI system resilience.
 - Encourage the use of AI cybersecurity frameworks such as MITRE Atlas and the OWASP Top 10 LLM to guide organizations in safeguarding AI models from exploitation, hacking, and unauthorized access.
 - Expand funding for AI security research, particularly in areas such as adversarial machine learning, secure multi-party computation, and federated learning to reduce vulnerabilities in AI systems.
3. Advancing Data Privacy and Security Throughout the AI Lifecycle
- Establish clear, risk-based guidelines for AI data governance, ensuring strong protections for consumer data without creating regulatory hurdles that stifle AI innovation.
 - Promote encryption and anonymization techniques for sensitive data used in AI training to minimize risks associated with data breaches and misuse.
 - Encourage the development of secure data-sharing ecosystems that enable AI-driven innovation while protecting proprietary and personally identifiable information.
 - Support legal frameworks that provide AI developers with clear guidance on ethical data usage, ensuring alignment with both domestic and international privacy regulations.
4. Defending Against AI Model Attacks and Ensuring System Integrity
- Prioritize investment in AI security research to develop robust defenses against model inversion, adversarial attacks, and intellectual property theft.
 - Foster public-private partnerships to share threat intelligence on emerging AI vulnerabilities and improve the resilience of AI infrastructure.
 - Require AI developers to implement security testing protocols, including adversarial robustness assessments, to ensure AI models remain reliable and tamper-resistant.
 - Encourage responsible disclosure programs that allow cybersecurity researchers to report AI system vulnerabilities without facing legal repercussions.
 - Mandate AI model scanning prior to deployment to identify potential security vulnerabilities and prevent the deployment of compromised models.
 - Implement runtime protection for AI models to detect and mitigate attacks in real time, ensuring continued model integrity and performance.
 - Promote the development and deployment of automated red teaming tools that continuously test AI systems for weaknesses, helping organizations proactively identify and address security threats before exploitation occurs.
5. Leverage and Extend Existing Cyber Security and Privacy Regulations when Possible
- Federal Information Security Modernization Act (FISMA) establishes a framework for protecting government information and operations from cybersecurity threats. It requires federal agencies to implement risk-based cybersecurity measures, making it applicable for AI systems used in government.
 - Health Insurance Portability and Accountability Act (HIPAA) includes security and privacy provisions to protect healthcare data, which can be applied to AI systems processing medical information. The HIPAA Security Rule enforces safeguards for electronic protected health information (ePHI), ensuring AI models handling such data remain secure.
 - Gramm-Leach-Bliley Act (GLBA) mandates financial institutions to protect consumer data. AI-driven financial systems must then comply with GLBA's Safeguards Rule to ensure confidentiality and integrity.
 - Defense Federal Acquisition Regulation Supplement (DFARS) & CMMC. These frameworks can apply to AI systems used in defense contracting by extending the cybersecurity

expectations to include AI specific threats and risks before a vendor contracts with the Department of Defense.

- Sarbanes-Oxley Act (SOX). Material Risk under SOX refers to financial, operational, or compliance risks that could significantly impact a company's financial statements, operations, or investor confidence. These risks must already be disclosed in financial filings, internal audits, and regulatory reports. SOX also mandates disclosure of any material weaknesses in internal controls. Thus unprotected AI models that can introduce or contribute to these risks should also be disclosed.

Securing AI models is critical to accelerating innovation and maintaining America's leadership in artificial intelligence. By integrating explainability, cybersecurity, data privacy, and AI attack defenses into policy frameworks, the U.S. can foster an environment where AI-driven economic growth is sustained while minimizing risks to our economy, national security, and consumer trust. These priority policy recommendations will ensure that America remains at the forefront of AI development while preventing unnecessary risks that could expose the country to harm and reduce real or perceived regulatory barriers that could hinder the private sector innovation that is the cornerstone of our country's success.

Thank you for the opportunity to submit comments to the OSTP AI Action plan efforts. The HiddenLayer team is eager to help to protect our advantage as a nation and enable AI to unleash dramatic economic and social benefits to our country. We are available for any questions you may have.

Respectfully,

Malcolm Harkins, Chief Security & Trust Officer, HiddenLayer

